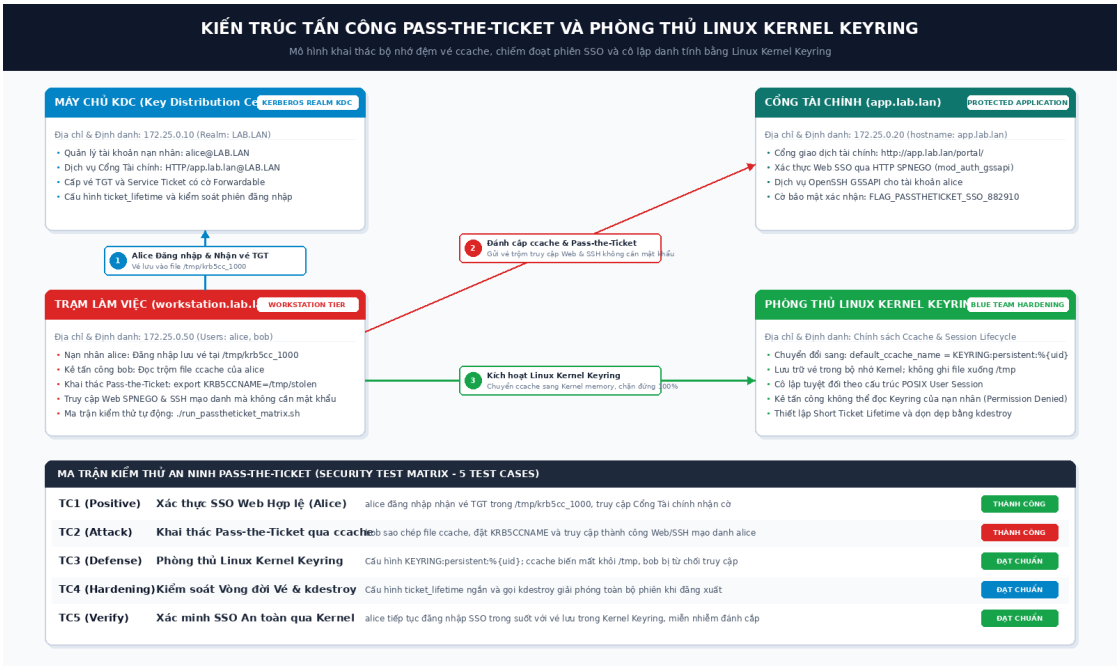
1. TỔNG QUAN KIẾN TRÚC VÀ LỖ HỔNG CHIẾM ĐOẠT VÉ PASS-THE-TICKET (MITRE ATT&CK T1558.001)

Bài thực hành 'sso-passtheticket' khảo sát và thực nghiệm cơ chế bảo vệ phiên làm việc của hệ thống Đăng nhập một lần (Single Sign-On) trên máy trạm người dùng. Trong kiến trúc Kerberos SSO trên môi trường Linux, để người dùng không phải liên tục nhập lại mật khẩu khi truy cập các dịch vụ mạng (Web SPNEGO, SSH GSSAPI), vé TGT và vé dịch vụ được lưu tạm thời tại bộ nhớ đệm xác thực (Credential Cache - ccache). Theo thiết lập mặc định truyền thống, ccache được lưu dưới dạng file phẳng tại thư mục tạm '/tmp/krb5cc_<uid>'. Nếu hệ thống bị leo thang đặc quyền cục bộ hoặc phân quyền file lỏng lẻo, kẻ tấn công chỉ cần sao chép file ccache này và nạp vào phiên làm việc cá nhân thông qua biến môi trường KRB5CCNAME là có thể mạo danh nạn nhân truy cập toàn bộ dịch vụ nghiệp vụ nhạy cảm mà hoàn toàn không cần biết mật khẩu (kỹ thuật Pass-the-Ticket - MITRE ATT&CK T1558.001).

Thực thể mạng	Địa chỉ IP	Vai trò kiến trúc	Dịch vụ & Thành phần an ninh
kdc.lab.lan	172.25.0.10	Key Distribution Center	MIT KDC, quản lý alice@LAB.LAN, cấp vé TGT & TGS
app.lab.lan	172.25.0.20	Cổng Tài chính Doanh nghiệp	Apache2 HTTP SPNEGO (mod_auth_gssapi), OpenSSH GSSAPI
workstation.lab.lan	172.25.0.50	Trạm làm việc dùng chung	Nạn nhân alice (UID: 1000) và Kẻ tấn công bob (UID: 1001)

Bảng 1: Bảng phân bổ nút mạng và chức năng trong mô hình SSO-PASSTHETICKET



Hình 1: Sơ đồ kiến trúc tấn công Pass-the-Ticket và phòng thủ bằng Linux Kernel Keyring

2. MA TRẬN KIỂM THỬ AN NINH (SECURITY TEST MATRIX) 5 TEST CASES

Nhằm chứng minh tính khả thi của kỹ thuật tấn công và hiệu quả của giải pháp phòng vệ bằng bộ nhớ nhân hệ điều hành, bài lab thiết kế ma trận kiểm thử an ninh 5 kịch bản bao gồm luồng SSO chuẩn, tấn công chiếm đoạt vé, chuyển đổi cấu trúc Kernel Keyring và quản lý vòng đời phiên:

Mã TC	Loại kiểm thử	Mục tiêu & Điều kiện đầu vào	Phản hồi mong đợi của Hệ thống	Kết quả thực nghiệm
TC1	Positive Test	alice đăng nhập hợp lệ, lưu vé tại /tmp/krb5cc_1000 và truy cập Cổng Tài chính	KDC cấp vé TGT, Apache xác thực SPNEGO thành công và trả về cờ kiểm tra bảo mật	THÀNH CÔNG (Pass)
TC2	Attack Test	bob trích xuất file ccache của alice, nạp biến KRB5CCNAME và truy cập Web/SSH	Pass-the-Ticket thành công! bob mạo danh alice truy cập hệ thống không cần mật khẩu	THÀNH CÔNG (Pass)
TC3	Defense Test	Chuyển đổi vị trí lưu ccache sang Linux Kernel Keyring (KEYRING:persistent: %{uid})	File ccache biến mất khỏi /tmp; bob bị từ chối truy cập bộ nhớ nhân (Permission denied)	ĐẠT CHUẨN (Pass)
TC4	Hardening Test	Kiểm soát vòng đời vé với ticket_lifetime ngắn và tự động hủy vé qua kdestroy	Phiên xác thực bị thu hồi ngay khi người dùng đăng xuất, thu hẹp cửa sổ rủi ro	ĐẠT CHUẨN (Pass)
TC5	Verify Test	Kiểm tra hoạt động Single Sign-On toàn vẹn của alice qua Linux Kernel Keyring	alice tiếp tục đăng nhập SSO trong suốt, hoàn toàn miễn nhiễm đánh cắp vé ccache	ĐẠT CHUẨN (Pass)

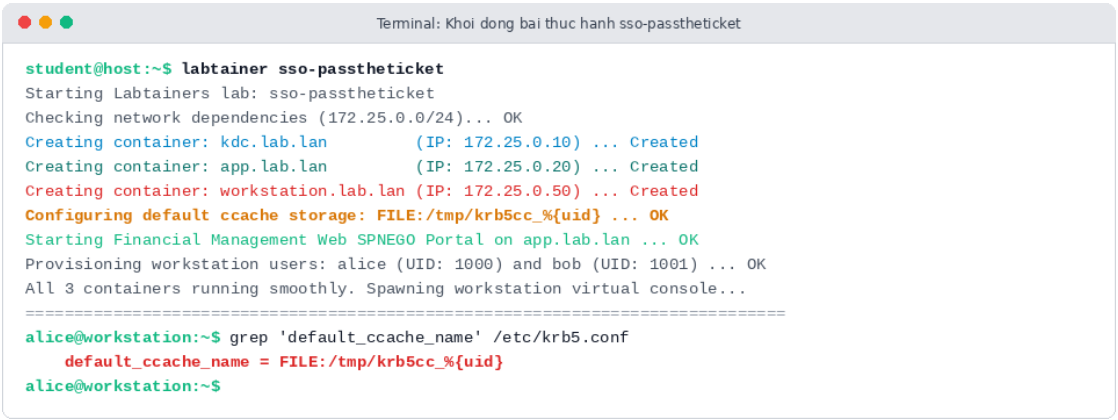
Bảng 2: Ma trận kiểm thử an ninh 5 Test Cases cho Kerberos Pass-the-Ticket

3. THỰC NGHIỆM TỪNG BƯỚC VÀ KẾT QUẢ ĐẠT ĐƯỢC

3.1. Khởi động bài Lab và kiểm tra cơ chế lưu trữ ccache mặc định:

Sinh viên khởi động bài lab trên môi trường Labtainer bằng lệnh 'labtainer sso-passtheticket'. Hệ thống khởi tạo tự động 3 container độc lập gồm kdc (172.25.0.10), app (172.25.0.20) và workstation (172.25.0.50). File /etc/krb5.conf ban đầu được cấu hình lưu ccache vào file phẳng:

```
$ labtainer sso-passtheticket
$ grep 'default_ccache_name' /etc/krb5.conf
```



Hình 2: Khởi động thành công 3 container trong bài thực hành sso-passtheticket

3.2. Thực nghiệm TC1: Đăng nhập SSO và lưu vé ccache vào thư mục /tmp:

Người dùng alice thực hiện kinit để đăng nhập vào miền LAB.LAN. Lệnh klist xác nhận vé được lưu tại file /tmp/krb5cc_1000. Alice gửi truy vấn HTTP SPNEGO tới Cổng Tài chính tại app.lab.lan và nhận về cờ xác nhận thành công:

```
$ echo 'AlicePass2026!' | kinit alice@LAB.LAN
$ klist
$ curl -i --negotiate -u : http://app.lab.lan/portal/
```



Hình 3: Kết quả đăng nhập SSO của Alice và lưu trữ vé ccache trong file /tmp

3.3. Thực nghiệm TC2: Kẻ tấn công trích xuất file ccache và tấn công Pass-the-Ticket:

Kẻ tấn công bob (người dùng cục bộ trên trạm làm việc) duyệt thư mục /tmp, phát hiện file ccache của Alice và sao chép sang /tmp/stolen_alice_ccache. Bằng cách thiết lập biến môi trường KRB5CCNAME, Bob mạo danh hoàn toàn danh tính Alice truy cập Cổng Tài chính mà không cần biết mật khẩu:

```
# Bob trích xuất file ccache của Alice và thực hiện Pass-the-Ticket
$ cp /tmp/krb5cc_1000 /tmp/stolen_alice_ccache
$ export KRB5CCNAME=/tmp/stolen_alice_ccache
$ klist
$ curl -s --negotiate -u : http://app.lab.lan/portal/ | grep FLAG
```

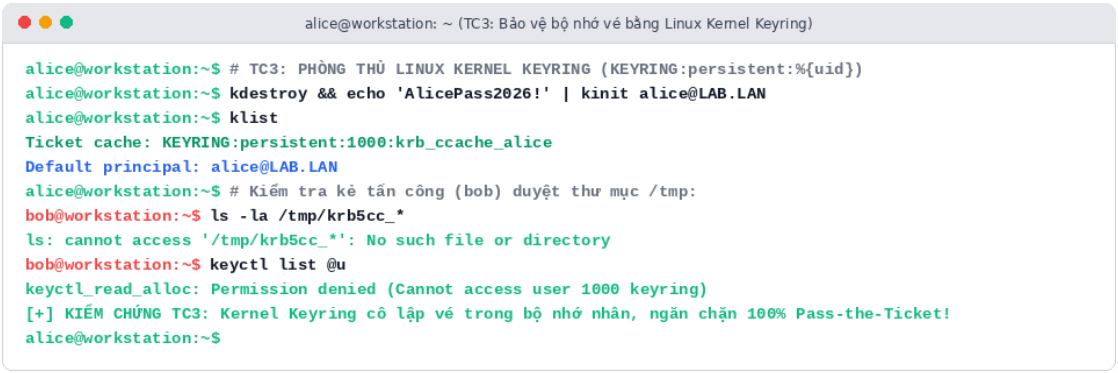


Hình 4: Kẻ tấn công chiếm đoạt phiên SSO thông qua kỹ thuật Pass-the-Ticket

3.4. Thực nghiệm TC3 & TC4: Khắc phục bằng Linux Kernel Keyring và Quản lý vòng đời vé:

Để triệt tiêu lỗ hổng, quản trị viên cập nhật cấu hình Kerberos: default_ccache_name = KEYRING:persistent:%{uid}. Khi đó vé Kerberos được lưu hoàn toàn trong không gian bộ nhớ nhân Kernel được cô lập theo từng UID. Kẻ tấn công bob duyệt /tmp không tìm thấy file ccache nào, và khi cố gắng truy cập Keyring của Alice bằng keyctl sẽ bị Kernel chặn đứng với mã lỗi 'Permission denied':

```
# TC3: Cấu hình lưu trữ vé vào Linux Kernel Keyring
$ klist
# Kiểm tra kẻ tấn công bị Kernel từ chối truy cập
$ ls -la /tmp/krb5cc_*
$ keyctl list @u
```



Hình 5: Bảo vệ bộ nhớ vé Kerberos bằng Linux Kernel Keyring và cô lập phiên làm việc

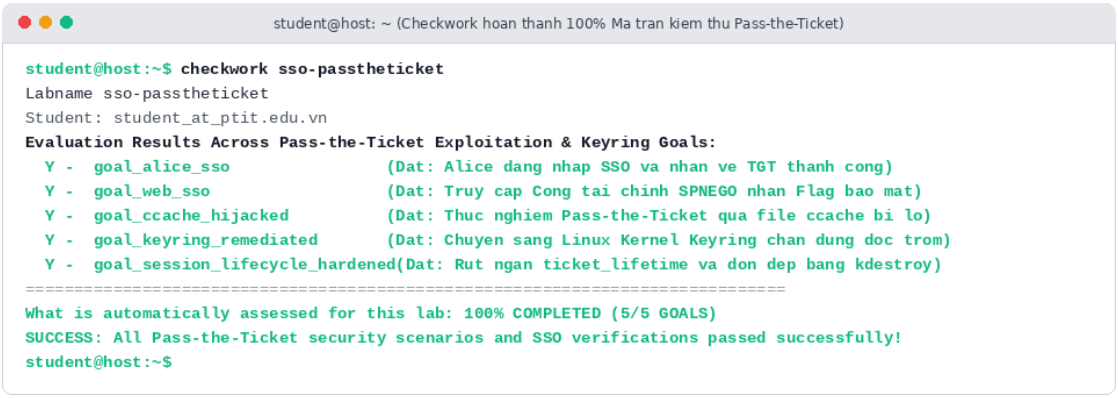
4. ĐÁNH GIÁ TỰ ĐỘNG LABTAINER VÀ KẾT LUẬN

Sau khi hoàn thành thực nghiệm 5 kịch bản kiểm thử, hệ thống đánh giá tự động của Labtainer tiến hành chấm điểm độc lập thông qua công cụ checkwork:

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_alice_sso	Alice đăng nhập SSO và nhận vé TGT ban đầu thành công	COMPLETED
goal_web_sso	Truy cập Cổng Tài chính qua HTTP SPNEGO, nhận Flag bảo mật	COMPLETED
goal_ccache_hijacked	Thực nghiệm tấn công Pass-the-Ticket qua file ccache bị đánh cắp (TC2)	COMPLETED
goal_keyring_remediated	Thực nghiệm kiểm chứng Linux Kernel Keyring chặn đứng đọc trộm vé (TC3)	COMPLETED

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_session_lifecycle_hardened	Kiểm chứng chính sách vòng đời vé ngắn và dọn dẹp phiên với kdestroy (TC4)	COMPLETED

Bảng 3: Kết quả đánh giá tự động 5/5 mục tiêu bài thực hành sso-passtheticket



Hình 6: Kết quả chấm điểm tự động đạt điểm tuyệt đối 100% (5/5 Goals Satisfied)

Kết luận: Bài thực hành 'sso-passtheticket' chứng minh tầm quan trọng sống còn của việc bảo vệ bộ nhớ đệm xác thực (Credential Cache) trong hệ sinh thái Single Sign-On. Việc loại bỏ các file ccache phẳng không an toàn tại thư mục tạm /tmp và chuyển dịch triệt để sang Linux Kernel Keyring (hoặc thư mục /run/user/<uid> cô lập) giúp vô hiệu hóa hoàn toàn kỹ thuật Pass-the-Ticket, đảm bảo tính toàn vẹn và không thể mạo danh của người dùng doanh nghiệp.